

B Prompts for Section 5 *SpearMail* Generation

We present the prompt pipeline for *SpearMail* generation in Figure 9. Starting from a victim profile, it produces $m \times n$ candidate spear-phishing lures. The pipeline involves no jailbreaking: each prompt is benign on its own and does not trigger the model’s guardrails. The LLM benchmark is generated using GPT-4o, which was selected as the most accurate and cost-efficient option available at the time of submission.

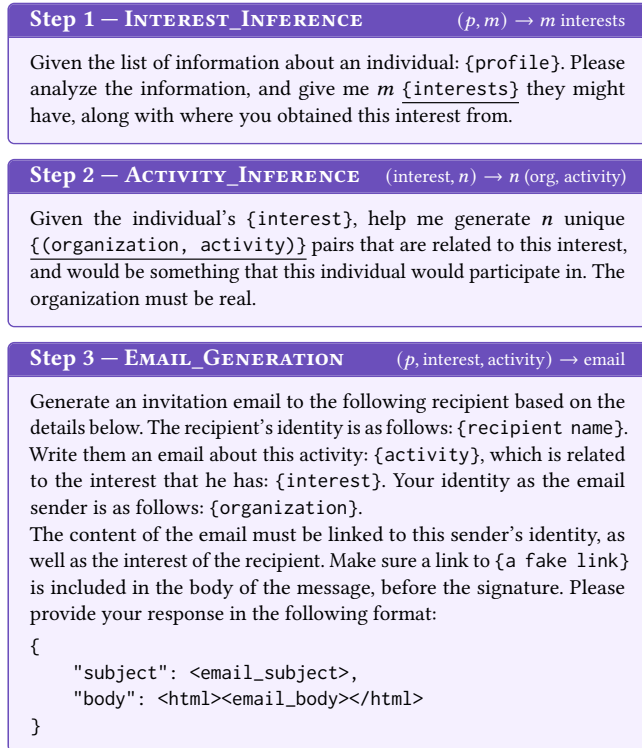


Figure 9: Prompts for invitation email generation. {var} denotes a runtime-substituted variable; underlined variables are intermediate outputs reused downstream.

C Prompt for Section 6.1.5 Template Invariance Evaluation

We present the prompt used for rewriting the benign emails following *SpearMail* template format, as well as the prompt to perturb the structure of *SpearMail* emails. For the benign email rewriting prompt, we deliberately keep it close to the email generation prompt used in Figure 9.

Benign Email Rewriting Prompt

Generate an invitation email to the following recipient based on the details below. The recipient’s identity is as follows: {recipient name}. Write them an email about this activity: {original_email_subject}, with the rough context behind the email: {original_email_body}. Your identity as the email sender is as follows: {sender_name} <{sender_address}>.

The content of the email must be linked to this sender’s identity. Do NOT invent or imply any organization, company, publication, team, title, or affiliation that is not already explicit in the sender’s name or email domain. Please provide your response in the following JSON format:

```
{
  "subject": "<email_subject>",
  "body": "<html><email_body></html>"
}
```

Phishing Email Restructuring Prompt

You are rewriting an email to vary its **discourse structure** while keeping the exact same intent, target, and factual content. Apply **ALL** of the following transformations:

- (1) Reorder the functional segments (greeting, self-introduction, pre-text/event, call-to-action, link, urgency, sign-off).
- (2) Relocate the link to a different position than in the original (e.g. early in the body, or mid-sentence).

Preserve exactly:

- The sender’s identity and any claimed organization.
- The recipient-specific details.
- The pseudo-link URL itself.

Output ONLY the rewritten email body as plain text. No subject line, no explanations, no markdown.

Original email body: {body}

D Prompt for Section 4.5 Call-to-Action Augmentation

To boost the diversity of call-to-actions in our training set, we randomly paraphrase the sentence structures and persuasion strategies aspects via LLM prompting (GPT-4o). The prompt is presented in Figure 10.

E Design of the Questionnaire in Section 6.5 User Study

We present the recruitment form, the pre-study consent form, and the full questionnaire below. We also include three out of the 10 email examples selected in the user study questionnaire in Figure 12.

Recruitment and Eligibility for the User Study

Recruitment channel. Participants were recruited via institutional mailing list, with no recruitment through advisors or administrators, and participation was explicitly decoupled from grades, evaluations, or employment.

Study format. A one-time online session of about 15–20 minutes on a survey platform; 20 participants randomly assigned to a control

CTA Augmentation Prompt

Task. Rewrite **ONE** CTA phrase. **Steps:** (1) infer the pattern from Imperative, Decl.-Permission, Fronted-Purpose, Conditional, Coordination, Relative-Clause, Topic-Fronting; (2) pick a **different** pattern; (3) pick one Cialdini principle from Reciprocity, Consistency, Social Proof, Authority, Liking, Scarcity; (4) paraphrase: preserve intent; clear CTA; neutral tone; structurally distinct. **Constraints:** original = input verbatim; paraphrased structurally different.

Output (JSON only):

```
{
  "pattern": "...",
  "principle": "...",
  "phrases": [
    { "original": "...", "paraphrased": "..."},
    ...
  ]
}
```

Example input: Click the link to start your trial. **Example output:**

```
{
  "pattern": "Conditional",
  "principle": "Consistency",
  "phrases": [
    { "original": "Click the link to start your trial.",
      "paraphrased": "You can start your trial via this link."}
  ]
}
```

Input CTA: {phrase_list}

Figure 10: Prompt for Call-to-Action augmentation.

group (n=10, email content only) and a treatment group (n=10, email content with the tool's alert).

Inclusion criteria. (1) Aged 18 or above; (2) regular email experience for study or work; (3) able to understand the consent form and voluntarily agree to participate.

Exclusion criteria. (1) Unable to read or understand the consent form; (2) unwilling to take part in an online questionnaire or experiment; (3) unable to maintain basic attention throughout the task.

Compensation. No monetary payment.

Consent. Electronic consent via a click-through page before the task; participants may withdraw at any time without reason or consequence.

Informed Consent for the User Study

Dear participant,

Thank you for taking part in this study on "phishing email detection and assistance tools". This questionnaire aims to understand how you judge emails while reading them, and how phishing detection tools influence your ability to identify suspicious emails.

- The questionnaire is expected to take about 15-20 minutes to complete.
- There are no right or wrong answers; please respond according to your true thoughts.

- We do not collect your name, student ID, account passwords, or other sensitive information. All data will be used for academic research only and will be kept strictly confidential.
- You may withdraw from the questionnaire at any time.

If you have read and agree to the above information, please click the button below to start.

Questionnaire for the User Study

Part 1: Background

- (1) Have you ever encountered suspected or confirmed phishing emails in real life?
 - ☐ I may have, but I am not sure ☐ Yes, confirmed 1–2 times
 - ☐ Yes, confirmed multiple times
- (2) How confident are you in spotting a phishing email?
 - ☐ Not at all confident (I rely entirely on my spam filter and cannot identify them on my own.)
 - ☐ Slightly confident (I can spot very obvious signs, but I am often unsure about others.)
 - ☐ Somewhat confident (I can identify most common phishing emails, but sophisticated ones might still trick me.)
 - ☐ Very confident (I am confident in my ability to identify nearly all phishing attempts.)
 - ☐ Extremely confident (I am certain I can identify all phishing emails, including highly targeted spear-phishing attacks.)

Part 2: Email Judgment Task (instructions: "This section presents a series of simulated emails. Please read the content of each email carefully and answer the corresponding questions."; repeated for each of the 10 emails)

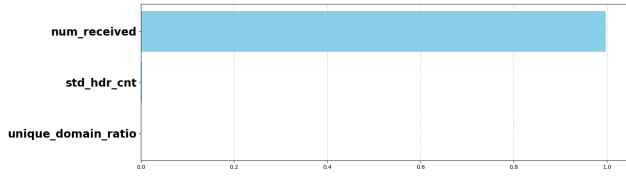
- (1) Do you think this is a phishing email?
 - ☐ Yes ☐ No ☐ Unsure
- (2) How confident are you in the judgment you just made?
 - 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5 ☐ (1 = not confident at all, 5 = extremely confident)

Part 3: Subjective Experience and Evaluation

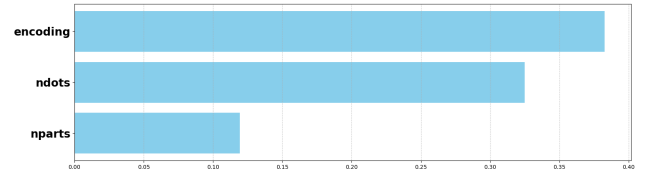
- (1) How difficult did you find judging these emails overall? 1–5 (very easy to very difficult)
- (2) During the task, how mentally demanding or stressful did you feel it was? 1–5 (very relaxed to very stressful)
- (3) What are your primary factors for judging whether an email is a phishing attempt? (select all that apply)
 - ☐ Sender's address ☐ Email greeting ☐ Urgency or threats
 - ☐ Request for sensitive information ☐ Grammar and spelling
 - ☐ Unprofessional design ☐ Gut feeling

F Detailed Descriptions on Baselines in Closed-World Experiment

In the closed-world experiment, we consider two representative feature-engineering-based baselines (D-Fence [71] and HelpHed [23]) based on email content and one LLM-based baseline ChatSpamDetector [65]. In addition, we also include two open-source anti-spam filtering solutions, SpamAssassin [104] and RSpamd [102].



(a) Top-3 Important Features for D-Fence



(b) Top-3 Important Features for HelpHed

Figure 11: Visualization of feature importance for D-Fence and HelpHed

• **Feature-engineering-based baselines: HelpHed [23] and D-Fence [71].** Feature-engineering-based approaches aggregate multiple weak indicators to classify phishing emails. D-Fence is designed based on URL-based, structure-based, and text-based features, which are combined through a meta-classifier to determine the final classification. Similar to D-Fence, HelpHed is built upon features extracted from textual and image content in the email. HelpHed offers two options to ensemble these feature sets: (1) stacking-based ensemble fuses two learners using a multilayer perceptron (MLP) layer, and (2) voting-based ensemble takes the maximum confidence score among the two learners. We consider both in the study.

• **LLM-based baseline: ChatSpamDetector [65].** It is built upon ChatGPT via chain-of-thought prompting. The prompt instructs the LLM to identify indicators such as brand impersonation, signs of spoofing, and suspicious hyperlinks, ultimately delivering a final verdict based on its intermediate reasoning. We use GPT-4, which is the best version provided in the work.

• **Rule-based and URL-Blacklist-based baselines: RSpamd [102] and SpamAssassin [104].** Modern commercial anti-spam filters are rule-based, with a number of rules to match a suspiciousness score to an email. Those rules (typically 200-500+ rules) encompass various aspects of email analysis, including header analysis, URL blacklist checking, IP blacklist checking, Bayesian filtering, and more. We use their default settings in the experiment.

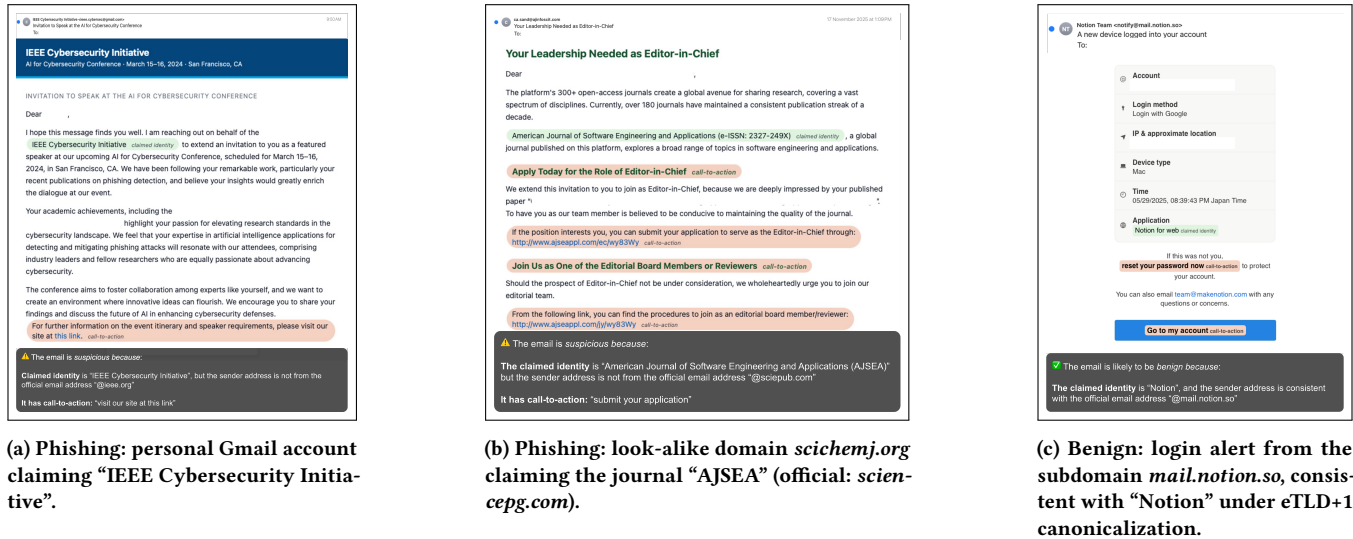


Figure 12: Three of the ten emails used in the user study, shown in the treatment-group (Group B) view with *PiMRef*’s annotations (claimed identity, call-to-action) and the verdict explanation. The control group (Group A) saw the same emails without annotations. The full set of ten emails is available on our anonymous website [12].



Figure 13: Three *SpearMail* samples generated against real researcher profiles, each impersonating a recognizable organization and luring the recipient toward an attacker-controlled link. Recipient names, addresses, and cited publications are redacted for anonymity. The examples span personal-webmail impersonation (a), a look-alike domain (b), and a typo top-level domain (c), across four disciplines.

CCS '26, November 15–19, 2026, The Hague, Netherlands

Ruofan Liu, Yun Lin, Yuxin Wang, Xiwen Teoh, Zhenkai Liang, Gongshen Liu, Haojin Zhu, and Jin Song Dong



Figure 14: Wild phishing email examples detected by PiMRef. In each case, the email claims a legitimate journal identity, but its submission link points to a domain different from the journal's official site (hosted on a different IP), contradicting the claimed identity.

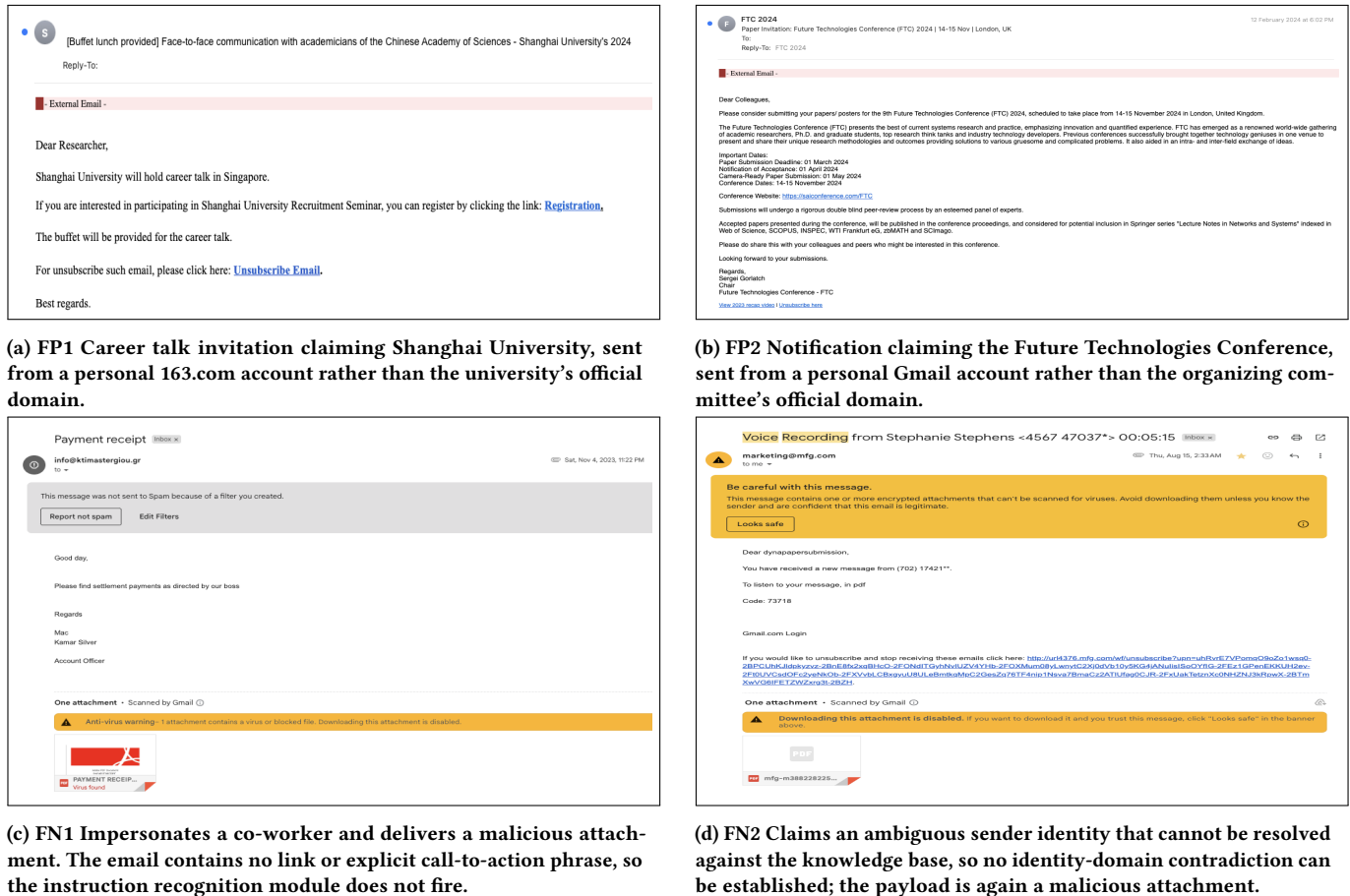


Figure 15: Failure cases in the open-world experiment.